Security and Network Settings

Implementation plan for developers and AI coding agents
Addendum to the Private Browser plan v1.0 · Android first · Version 1.0 · 20 October 2026

Scope. 55 selected settings: proxy, OpenVPN and WireGuard, user agent and identity, JavaScript and content controls, fingerprint hardening, permissions and downloads, lock and panic, safety checks, and the Settings screens that expose them. Everything uses the feature IDs below. The main plan's rules still apply: encrypted database, no analytics, no logging of URLs or credentials, build only registered features.

Contents

- 1. Rules for AI agents
- 2. Feature register
- 3. Architecture and cross-cutting rules
- 4. Delivery phases S0 to S6
- 5. Data model additions
- 6. Decisions needed from the owner
- 7. Risks and platform limits
- 8. Testing and QA
- 9. New design screens needed
- Appendix: agent kickoff prompt

1. Rules for AI agents

- **Prerequisites.** Start only after the main plan's Phase 0 (foundations), Phase 1 (encrypted database and lock) and Phase 2 (browser shell) are done. Phases S1 and S2 reuse the request interceptor from main Phase 4 (blocker); build them on the same interceptor, not a second one.
- **Build only registered IDs.** Anything else goes under 'Proposed changes' in the pull request.
- **Credentials are secrets.** Proxy, VPN and key material live only in the encrypted database. Never log them, never put them in notifications or crash logs, never send them to any host other than the configured endpoint.
- **One routing policy for all traffic.** The proxy, VPN and kill switch rules apply to WebView traffic, the download service, list updates and test requests alike. A feature that bypasses them is a bug.
- **Check support at runtime.** Use androidx.webkit WebViewFeature.isFeatureSupported before using a WebView API, and show 'Not supported on this device' in Settings when a feature is missing. Where this plan says 'verify', read the current docs before coding.
- **Degrade safely.** If a protection cannot be applied, fail closed (block or warn) for network rules and fail open with a visible notice for cosmetic rules.
- **Finish every task** with tests, a CHANGELOG line and a check against the phase acceptance criteria.

2. Feature register

Tier: **Core** = requested by the owner, **Rec.** = recommended, **Opt.** = optional. All rows were selected.

ID	Feature	Tier	Phase
NET-1	HTTP/HTTPS proxy	Core	S3
NET-2	SOCKS5 proxy (remote DNS)	Core	S3
NET-3	Proxy login	Core	S3
NET-4	Saved proxy profiles	Rec.	S3
NET-5	Test connection	Rec.	S3
NET-6	Block traffic if the proxy fails	Rec.	S3
VPN-1	Import .ovpn file	Core	S4
VPN-2	Import certificates and keys	Core	S4
VPN-3	Saved VPN login	Core	S4
VPN-4	Connect and disconnect switch	Core	S4
VPN-5	Only this app uses the VPN	Rec.	S4
VPN-6	Kill switch	Rec.	S4
VPN-7	Config safety check	Rec.	S4
VPN-8	Multiple VPN profiles	Rec.	S4
VPN-9	Auto-connect on launch	Rec.	S4
VPN-10	Block IPv6 leaks	Rec.	S4
VPN-11	WireGuard import	Opt.	S4
IDN-1	Custom user agent	Core	S2
IDN-2	Random user agent (real pool)	Core	S2
IDN-3	User agent presets	Rec.	S2
IDN-4	Per-site user agent	Rec.	S2
IDN-5	Keep details consistent (Client Hints, platform)	Rec.	S2
IDN-6	Language override	Opt.	S2
IDN-7	Timezone override	Opt.	S2
IDN-8	Round screen size	Opt.	S2
SCR-1	Disable JavaScript	Core	S1

ID	Feature	Tier	Phase
SCR-2	Per-site JavaScript	Core	S1
SCR-3	Block third-party scripts	Rec.	S1
SCR-4	Block autoplay media	Rec.	S1
SCR-5	Block local network access	Rec.	S1
SCR-6	Block images	Opt.	S1
SCR-7	Block remote fonts	Opt.	S1
SCR-8	Block service workers	Opt.	S1
SCR-9	Block beacons and ping	Opt.	S1
FPH-1	Canvas and audio noise	Opt.	S2
FPH-2	Hide hardware details	Opt.	S2
FPH-3	Limit device enumeration	Opt.	S2
PRM-1	Deny sensitive permissions by default	Rec.	S1
PRM-2	Permissions manager	Rec.	S1
PRM-3	Block clipboard reads	Rec.	S1
PRM-4	Warn on risky downloads	Rec.	S1
PRM-5	Block downloads without a tap	Rec.	S1
PRM-6	Ask before opening other apps	Rec.	S1
LCK-1	Lock when the screen turns off	Rec.	S5
LCK-2	Private keyboard	Rec.	S5
LCK-3	Panic wipe	Rec.	S5
LCK-4	Wipe after failed unlocks	Opt.	S5
LCK-5	Duress password	Opt.	S5
LCK-6	Clear on exit	Opt.	S5
SAF-1	Certificate details	Rec.	S6
SAF-2	Warn on insecure forms	Rec.	S6
SAF-3	Per-site settings page	Rec.	S6
SAF-4	Leak test page	Opt.	S6
SET-1	Security settings section (iOS-style groups)	Core	S0
SET-2	VPN and proxy indicator	Rec.	S4

3. Architecture and cross-cutting rules

Policy engine

Add one native component, the **PolicyEngine**, that holds the effective settings for each request: global settings, then per-site overrides (a site setting beats a global one). Everything in this addendum reads from it; nothing reads raw settings directly.

```
Request from WebView
   |
   v
[1 Route gate]    kill switch / proxy-failed / VPN-down  -> block
[2 Site policy]   JS, images, fonts, 3rd-party scripts,
                  local network, beacons, downloads      -> block or allow
[3 Blocker]       ad/tracker rules (main plan Phase 4)   -> block or allow
[4 Observe]       media detection (main plan Phase 5)
   |
   v
Network (WebView proxy override, or VPN tunnel for this app)

Page start:  addDocumentStartJavaScript injects identity, fingerprint,
             clipboard, beacon and form-guard scripts (all frames)
```

Key facts that shape the design

- **UA changes need a reload.** The user agent is a WebView setting, so per-site rules are applied before each main-frame navigation, and the page reloads if the rule changed.
- **The interceptor can block but cannot rewrite headers.** Rewriting subresource headers (for example Accept-Language) would mean fetching every request yourself, which this plan does not do. Those items are marked partial where it matters.
- **Injected scripts need JavaScript.** With JavaScript off, identity, fingerprint, clipboard and form-guard scripts, cosmetic filtering and page-based video detection do not run. Network-level rules and native settings still do.
- **Non-WebView traffic follows the same route.** The download service and list updates use OkHttp configured with the active proxy. With a VPN on, they are already inside the tunnel because this app is the routed app.
- **Per-site key.** Site rules are stored by hostname and inherit from the parent domain unless a more specific rule exists.

Where things live

```
modules/private-browser-native/
  policy/        PolicyEngine, site rule store, route gate
  proxy/         ProxyController wrapper, local relay (SOCKS5 with login)
  vpn/           VpnService, OpenVPN/WireGuard adapters, config parser
  inject/        document-start scripts (identity, fingerprint, guards)
  security/      panic wipe, failed-attempt counter, screen-off receiver
src/settings/    Network, Identity, Content, Permissions, Lock, Safety screens
src/security/    duress and panic flows (UI side)
```

4. Delivery phases S0 to S6

Size guide: S = under 2 days, M = about a week, L = 2 weeks or more, for one developer with an AI agent.

Phase S0: Settings foundation and spikes (size M)

Goal. Data model, policy engine skeleton, Settings navigation and the technical spikes that decide later phases (SET-1).

Tasks

- Add the tables in section 5 with migrations. Build the PolicyEngine with global and per-site resolution and unit tests for precedence.
- Build the new Settings groups in the existing iOS-style design: Network, Identity, Content, Permissions, Lock and Data, Safety (SET-1). Screens can show 'Not supported' states.
- Spike 1: confirm which proxy schemes androidx.webkit ProxyController supports on the target WebView versions, including SOCKS, and whether it can be set per profile or only app-wide.
- Spike 2: confirm WebViewFeature support for DOCUMENT_START_SCRIPT, USER_AGENT_METADATA and proxy override on the three test devices.
- Spike 3: decide the VPN library with the owner (decision D-1 in section 6).

Acceptance criteria

✓ Resolving a setting for a host returns the site rule when present, else the global value, covered by tests.

✓ Every new Settings screen opens and shows current values from the encrypted DB.

✓ Spike notes committed in docs/ with a recommendation.

Phase S1: Content controls and permissions (size L)

Goal. Script, content and permission controls through the shared interceptor (SCR-1 to SCR-9, PRM-1 to PRM-6).

Tasks

- **SCR-1, SCR-2 JavaScript.** Set JavaScript per WebView from the resolved policy before each main-frame navigation. Address-bar menu offers 'JavaScript: on or off for this site' and shows when the global switch is off. Show a notice that page-based video detection and cosmetic filtering pause on JS-off sites.
- **SCR-3 third-party scripts.** First choice: in the interceptor, block script requests whose registrable domain differs from the page's, identifying scripts by Sec-Fetch-Dest where present, else by extension and Accept header (verify what WebView exposes). Second option if unreliable: inject a Content-Security-Policy meta tag at document start restricting script-src to 'self'. Per-site allow always wins.
- **SCR-4 autoplay.** Require a user gesture for media playback. **SCR-6 images.** Use the WebView block-network-image setting.
- **SCR-5 local network.** Block requests from public pages to localhost, loopback, link-local and private ranges (RFC 1918 and unique-local IPv6). Resolve hostnames before allowing, to catch names that point inward; document that DNS rebinding cannot be fully closed this way.
- **SCR-7 fonts.** Block font requests by extension and Accept header, or CSP font-src 'none' when the CSP route is active.
- **SCR-8 service workers.** Block through the WebView service worker controller where available, otherwise remove navigator.serviceWorker at document start (verify).
- **SCR-9 beacons and ping.** Block requests carrying Ping-From or Ping-To headers; inject a script that strips ping attributes and turns navigator.sendBeacon into a no-op.
- **PRM-1, PRM-2 permissions.** In the WebChromeClient permission callbacks, deny camera, microphone, location, MIDI and protected-media requests by default; ask only on an explicit per-site choice. Store decisions in site_permissions; the manager lists and revokes them.
- **PRM-3 clipboard.** Injected script makes navigator.clipboard.readText and read reject. **PRM-4 risky downloads.** In the download listener, confirm before .apk, .xapk, .exe, .msi, .bat, .sh, .jar, .dex and script files, showing file name and host. Video downloads from the app's own engine are exempt.
- **PRM-5 drive-by downloads.** Track the last user touch time natively; a download that starts without a tap in the previous 1.5 seconds is blocked with a banner offering 'Allow once'.
- **PRM-6 other apps.** For non-http(s) schemes ask before opening. For intent: URLs, parse safely: clear component and selector, require the BROWSABLE category, then show the target app name in the confirmation.

Acceptance criteria

✓ A test page set confirms each blocker works and each has a per-site allow switch.

✓ With JavaScript off on a site, the site loads its static content and the video list still shows network-detected videos.

✓ Permission requests from a test page are denied without a prompt by default; granting one for a site is visible and revocable in the manager.

✓ A drive-by download page is blocked; an intent: link with a component extra is sanitized (fuzz tests).

Phase S2: Identity and fingerprint hardening (size L)

Goal. Control what sites can learn about the device (IDN-1 to IDN-8, FPH-1 to FPH-3).

Tasks

- **IDN-1 custom UA.** Validate: not empty, at most 512 characters, no control characters or line breaks (header injection). Offer reset to default. The default UA should look like mobile Chrome, with the WebView markers ('; wv' and 'Version/x.x') removed, because some sites reject WebView agents.
- **IDN-3 presets.** Chrome Android, Safari iPhone, Firefox Android, Chrome Windows, Safari Mac. Each preset carries matching platform, vendor and Client Hints values.
- **IDN-2 random UA.** Choose from a bundled pool of real, current agents; rotate per session or per site (setting). Ship the pool in the signed list updates from the blocker so versions do not go stale; reject entries more than a set number of major versions old. Never generate invented strings.
- **IDN-4 per-site UA.** Stored in site_settings; applied before navigation with a reload when it changed.

- **IDN-5 consistency.** Apply WebSettingsCompat user agent metadata (brands, platform, mobile flag) and a document-start script for navigator.platform, vendor, userAgentData and appVersion so they match the chosen UA. Include an offline self-check page that flags mismatches.
- **IDN-6 language.** Override navigator.language and languages and the main-frame Accept-Language header. Subresource headers keep the device value (partial, stated in the UI).
- **IDN-7 timezone.** The user picks an IANA zone manually (no location lookup). Script overrides Intl resolved timezone and Date offset methods. Partial coverage is stated in the UI.
- **IDN-8 screen size.** Report bucketed values for screen and window sizes in JavaScript. Does not change CSS media queries (stated in the UI).
- **FPH-1 canvas and audio.** Add small seeded noise to canvas readouts and audio buffers, seed per session and origin. Per-site switch because it can break canvas-heavy apps.
- **FPH-2 hardware.** Standardize hardwareConcurrency and deviceMemory; remove the Battery API and generic sensor APIs; standardize connection info. **FPH-3 devices.** enumerateDevices returns an empty or generic list until permission is granted.

Acceptance criteria

✓ The offline self-check page shows the chosen UA in the header, navigator.userAgent, userAgentData and platform, all consistent for every preset.

✓ Random mode changes the UA per session or per site as configured, drawn only from the pool.

✓ Two sessions produce different canvas hashes with FPH-1 on and identical hashes with it off.

✓ Custom UA with a line break is rejected.

Phase S3: Proxy (size M)

Goal. App-wide proxy with login, profiles, testing and fail-closed behavior (NET-1 to NET-6).

Tasks

- **NET-1, NET-2.** Apply the proxy through ProxyController with the scheme confirmed in Spike 1. Do not add a direct fallback rule (needed for NET-6). Remote DNS comes from the SOCKS5 mode; confirm with a DNS leak test.
- **NET-3 login.** HTTP proxies: answer the 407 challenge in onReceivedHttpAuthRequest, but only when the challenge host and port equal the configured proxy. Never offer these credentials to a site. SOCKS5 with a username: Chromium does not support SOCKS5 authentication (verify), so run an in-app local relay on loopback with a random port that connects upstream with the credentials, and make the WebView use the relay as an HTTP proxy protected by a random token passed through the same 407 handshake.
- **NET-4 profiles.** CRUD for proxy_profiles with name, type, host, port, login. One active profile at a time. Switching applies immediately and reloads open tabs.
- **NET-5 test.** User-initiated check: connect to the proxy, complete the handshake, then request a user-configurable test URL (default example.com) and report success and time. No automatic tests.
- **NET-6 fail closed.** No direct fallback. On proxy connection errors show an interstitial 'Proxy unreachable, traffic blocked' with Retry, Edit and Turn off proxy.
- Route the download service and list updates through the same proxy using OkHttp.

Acceptance criteria

✓ With a test HTTP proxy and a test SOCKS5 proxy (with and without login), pages load and the proxy's logs show the requests.

✓ Stopping the proxy blocks all page loads, downloads and updates; nothing connects directly (verified with packet capture).

✓ Credentials are never presented to a test site that asks for Basic auth.

✓ DNS leak test shows lookups through the proxy in SOCKS5 mode.

Phase S4: VPN (OpenVPN and WireGuard) (size L)

Goal. Import, store and run VPN profiles for this app only (VPN-1 to VPN-11, SET-2).

Tasks

- **Library.** Implement the choice from decision D-1. All options run inside a VpnService owned by the native module.
- **VPN-1, VPN-2 import.** File picker for .ovpn. The parser extracts inline blocks (ca, cert, key, tls-auth, tls-crypt, pkcs12) and finds external file references. For each missing referenced file, the import flow asks the user to pick it. A passphrase prompt covers encrypted keys and .p12 files. Everything is stored in the encrypted DB, not as loose files.
- **VPN-7 safety check.** Reject: up, down, route-up, route-pre-down, ipchange, client-connect, client-disconnect, tls-verify, auth-user-pass-verify, learn-address, plugin, management, config, log, log-append, writepid, cd, chroot, daemon, and script-security above 1. Warn: BF-CBC or DES ciphers, MD5 or SHA1 auth, compression, tls-version-min below 1.2, missing remote-cert-tls or verify-x509-name, missing CA. Show a report with errors (import blocked) and warnings (allowed).
- **VPN-3 login.** Store username and password for auth-user-pass encrypted; masked in the UI.
- **VPN-4 switch.** First use shows the system VPN consent dialog. States: disconnected, connecting, connected, reconnecting, blocked. **VPN-5 per app.** addAllowedApplication with this app's package only; the rest of the phone is untouched.
- **VPN-6 kill switch.** If the tunnel drops, keep the VPN interface established and route this app's traffic into a drop-all sink while reconnecting, so nothing leaks. Tabs show 'VPN reconnecting, traffic blocked'. Also offer a shortcut to the system VPN settings for the always-on option.
- **VPN-10 IPv6.** Capture IPv6 with a ::/0 route and either tunnel it (if the server supports it) or drop it.
- **VPN-8 profiles.** Save, rename, switch, delete. Delete removes rows, key material and credentials, then checkpoints and vacuums the DB. **VPN-9 auto-connect.** After unlock, connect the flagged profile; with the kill switch on, tabs wait for the tunnel before loading.
- **VPN-11 WireGuard.** Parse .conf, store encrypted, run through the WireGuard tunnel library under the same switch, per-app and kill-switch rules.
- **SET-2 indicator.** A small status mark in the address bar: green for connected VPN, blue for proxy, amber for reconnecting or blocked. Driven by a native status event.

Acceptance criteria

✓ Importing a valid test .ovpn with inline certs and with separate files both connect to a test server.

✓ A config containing 'up' or 'management' is rejected with a clear message; a config with BF-CBC imports with a warning.

✓ Only this app's traffic goes through the tunnel (verified from another app and from the server logs).

✓ Killing the server shows the blocked state and zero packets leaving the device (packet capture on the test network); reconnect resumes.

✓ Deleting a profile removes it from a decrypted DB dump.

Phase S5: Lock and panic (size M)

Goal. Stronger lock behavior and emergency erase (LCK-1 to LCK-6).

Tasks

- **LCK-1.** Register a screen-off receiver that locks immediately (closes the DB, drops the key). Downloads in progress continue from in-memory state as designed in the main plan.
- **LCK-2 private keyboard.** Set no-personalized-learning on the IME options for the URL bar, password fields and web inputs (through the own WebView view's input connection), disable autocorrect and autofill hints, and turn off WebView autofill.
- **LCK-3 panic wipe.** Works without unlocking. Order: delete the wrapped database key and Keystore aliases first (this makes the DB unrecoverable), then delete the DB, VPN and proxy data, app-private temp files and WebView data, then reset the app to first-run state. Triggers: a button in Settings and the tab menu, a shake gesture (switchable) and a launcher shortcut. Option 'also delete downloaded videos' defaults to off.

Completes in under a second on a mid-range phone.

- **LCK-4 failed unlocks.** Keep the counter outside the DB, protected with a Keystore HMAC key. Increment it before each attempt is checked so killing the app cannot avoid it. Warn two attempts before the limit; on the limit run the panic wipe. The user picks the limit.
- **LCK-5 duress password.** A second password, different from the main one. Entering it silently runs the panic wipe and opens the app in a clean first-run-like state with empty data. Always compute both key derivations on every attempt so timing does not reveal which password was tried.
- **LCK-6 clear on exit.** When the task is removed from recents or the app is closed, clear tabs and WebView data. Finish any interrupted clear at the next launch using a flag. Active downloads are not cancelled unless the user chose that.

Acceptance criteria

✓ After a panic wipe, the app's data directory contains no database and the Keystore aliases are gone (forensic check).

✓ Wrong password the configured number of times triggers the wipe, including when the app is killed between attempts.

✓ Duress and main password attempts take the same time within a small margin.

✓ Keyboard suggestions do not learn from typed text on test keyboards that honor the flag.

Phase S6: Safety checks, site settings and release (size M)

Goal. Visibility tools, one place to manage a site, and final QA (SAF-1 to SAF-4).

Tasks

- **SAF-1 certificate.** Tapping the lock shows issuer, subject, validity dates and the SHA-256 fingerprint from the main-frame certificate. TLS version and cipher are not exposed by WebView and are not shown.
- **SAF-2 insecure forms.** Injected listener on form submit: warn when a form with a password field loads over http, or posts from https to an http action. The user can continue or cancel. A banner marks http pages that contain a password field.
- **SAF-3 site settings.** One screen per site, reached from the address bar: JavaScript, user agent, images, third-party scripts, fingerprint protection, blocker, and permissions, each showing 'Default' or 'Custom'. A list of all customized sites with 'Reset all'.
- **SAF-4 leak test.** Offline self-check always available (what the page sees: UA, languages, screen, timezone, WebRTC candidates). Optional IP check that calls a URL the user enters; no default third-party endpoint.
- Full regression pass on all phases; threat-model review against section 7; update the plan docs and CHANGELOG.

Acceptance criteria

✓ Certificate sheet matches the values from a test site.

✓ A test page that posts a password over http shows the warning; HTTPS forms do not.

✓ Resetting a site restores every setting to the global value.

✓ All acceptance criteria from S0 to S5 pass on three physical devices.

5. Data model additions (encrypted SQLite)

```
proxy_profiles(id TEXT PK, name TEXT, type TEXT,        -- http | https | socks5
               host TEXT, port INTEGER, username TEXT, password TEXT,
               active INTEGER DEFAULT 0, created_at INTEGER)

vpn_profiles(id TEXT PK, name TEXT, kind TEXT,          -- openvpn | wireguard
             config TEXT,                               -- sanitized config text
             username TEXT, password TEXT,
             kill_switch INTEGER DEFAULT 1, auto_connect INTEGER DEFAULT 0,
             created_at INTEGER, last_used INTEGER)
vpn_blobs(profile_id TEXT REFERENCES vpn_profiles(id) ON DELETE CASCADE,
          role TEXT,                                    -- ca|cert|key|tls-auth|tls-crypt|p12
```

```
          data BLOB, passphrase TEXT)

site_settings(host TEXT PK, js INTEGER, ua_mode TEXT, ua_value TEXT,
              images INTEGER, third_party_scripts INTEGER,
              fp_protection INTEGER, blocker INTEGER, updated_at INTEGER)
site_permissions(host TEXT, permission TEXT, decision TEXT,   -- allow | deny
                 PRIMARY KEY(host, permission))
-- global toggles live in settings(key, value); NULL in a site column = inherit
```

Stored outside the database: the failed-unlock counter and its HMAC (Keystore-protected), and the wrapped database key blobs from the main plan. Panic wipe deletes both groups.

6. Decisions needed from the owner

#	Decision	Options and recommendation
D-1	VPN library and license	(a) Embed an OpenVPN Android core: most complete, but common cores are GPL or AGPL, so the app would need compatible licensing and source release. (b) Use WireGuard's Apache-licensed library only: simple and permissive, but not OpenVPN. (c) Talk to the separate 'OpenVPN for Android' app through its remote API: keeps your app's license free, but needs that app installed and gives weaker per-app control. Decide before Phase S4.
D-2	Proxy and VPN together	Allowed by default: the proxy's traffic then goes through the tunnel. Say if you want them mutually exclusive.
D-3	Duress behavior	This plan silently wipes real data and opens an empty app. The alternative, a separate decoy database, leaves two databases on disk and is less safe.
D-4	Panic wipe and downloaded files	Default keeps downloaded video files in Downloads. Deleting them is a switch.
D-5	Random user agent pool updates	Pool refreshes through the signed list update channel. Without it the pool goes stale and becomes a fingerprint.

7. Risks and platform limits

Item	Detail
WebView version differences	Several APIs (document-start scripts, user agent metadata, proxy override) depend on the installed WebView. Check support at runtime and show 'Not supported'.
Spoofing is partial	Timezone, language and screen overrides change what JavaScript reads, not everything the browser does. Inconsistent spoofing can make a user more unique. The UI says 'partial' where true.
User agent and sites	Some sites change behavior or block unusual agents. Per-site overrides and a quick reset in the address bar menu are the safety valve.
JavaScript off	Breaks many sites and pauses injected features. The per-site switch and the visible notice reduce the pain.
SOCKS5 login	Needs the in-app relay (S3). The relay listens on loopback only, with a random port and token.
Local network blocking	Cannot fully close DNS rebinding from the interceptor alone.
VPN consent and store policy	The system shows a VPN consent dialog, and stores have VPN app policies. An APK release avoids store review, as in the main plan.
iOS differs	Per-site JavaScript and custom UA exist in WKWebView, proxies need iOS 17 or later, and a VPN needs a NetworkExtension target with an Apple entitlement. Plan iOS as a separate phase after Android.
Panic wipe is irreversible	Confirm for button use; no confirm for gesture and duress paths by design.

8. Testing and QA

- **Unit:** policy resolution, UA validation, .ovpn parser and deny-list, WireGuard parser, intent sanitizer, failed-attempt counter, timezone and screen override helpers.
- **Test infrastructure:** a Docker compose with an OpenVPN server, a WireGuard server, an HTTP proxy and a SOCKS5 proxy (with and without login), plus a test web server with pages for scripts, images, fonts, service

workers, beacons, forms, downloads and intent links.

- **Leak tests:** packet capture on the test network while stopping the proxy or VPN; DNS leak check against the test resolver's logs; WebRTC candidate check.
- **Forensics:** pull the app data directory after panic wipe and after duress unlock; confirm no database, no credentials and no Keystore alias remain.
- **E2E (Maestro):** import a VPN, connect, kill the server, observe blocked state, reconnect; add a proxy, test, switch; set a per-site user agent and check the self-check page; trigger each permission and download case.
- **Devices:** three physical Android devices on two Android versions, with different WebView versions.

9. New design screens needed

These screens are not in the current UI design yet. Design them in the same iOS-style system before or during the related phase:

- Settings: Network (proxy list and VPN list), Add or edit proxy, VPN import flow with validation report and file picker steps.
- Settings: Identity, Content, Permissions, Lock and Data (with panic confirmation), Safety.
- Website Settings sheet from the address bar; Certificate sheet; Risky download warning sheet; Other-app confirmation sheet.
- Interstitials: 'Proxy unreachable', 'VPN reconnecting, traffic blocked', 'Insecure form' warning; address-bar status mark states.

Appendix: agent kickoff prompt

```
You are adding security and network settings to the Private Browser
(Expo / React Native, Android first). Read the main plan and this addendum
fully before coding. Rules: build only registered IDs; follow the phase
order S0 to S6; credentials only in the encrypted DB and never logged; one
routing policy for all app traffic; check WebView features at runtime; where
the plan says 'verify', read the current docs first and pin versions; reference
feature IDs in commits; finish each task with tests, a CHANGELOG line and a
check against the phase acceptance criteria. If something is unclear or
needs an owner decision (section 6), stop and ask.
Current task: Phase S__ , features __ .
```